للمتدرب

كراسة التمارين

كيف تبدأ في GRC · 12 تمريناً، منها 4 تطبيقات موجهة على شركة واحدة

بيانات تدريبية افتراضية — رُفاد للخدمات اللوجستية (شركة افتراضية لأغراض التدريب)

كيف تستخدم هذه الكراسة

- التمارين بترتيب العرض. في رأس كل تمرين رقم الشريحة التي يبدأ عندها، ورقم شريحة الإجابة.
- حين تظهر شريحة «تمرين · توقف وطبّق» أوقف الفيديو، واكتب إجابتك في الكراسة، ثم أكمل المشاهدة.
- التطبيقات الأربعة تسير بالطريقة نفسها: مثال محلول تشاهده في العرض، وملخصه هنا للرجوع إليه، ثم حالة مشابهة تحلها أنت.
- بعد أن تكتب، راجع قائمة «راجع نفسك» في آخر التمرين، ثم قارن بالإجابة النموذجية في العرض وفي ملف «الإجابات النموذجية وطريقة الحل».
- احكم من البيانات المعطاة فقط. ما تحتاجه ولم تجده اكتبه «معلومة ناقصة»، ولا تخترع دليلاً.
- كل التطبيقات على شركة واحدة، فما تكتبه في تطبيق يُستخدم في التالي، ثم في ملف أعمالك وسيرتك ومقابلتك.

حدود الكورس: هذه الكراسة جزء من كورس تأسيسي. التمارين تبني مهارات أولى في GRC، ولا تؤهل وحدها لإدارة برنامج GRC أو تطبيق الضوابط الأساسية كاملة.

الحالة: رُفاد للخدمات اللوجستية

تنبيه: رُفاد شركة افتراضية لأغراض التدريب. اسمها وأشخاصها وأنظمتها وبياناتها وأدلتها مختلقة، وأي تشابه مع جهة حقيقية غير مقصود.

شركة افتراضية متوسطة الحجم في الرياض، نحو 200 موظف، تقدم خدمات التوصيل والتخزين للمتاجر الإلكترونية.

رُفاد شركة خاصة ليست جهة حكومية ولا تابعة لجهة حكومية، ولا تملك بنية تحتية وطنية حساسة، فالضوابط الأساسية ECC-2:2024 غير ملزمة لها. في هذه الحالة التدريبية تبنّتها رُفاد طوعاً مرجعاً داخلياً. وتبنّت طوعاً كذلك مصفوفة تقييم المخاطر في الإطار الوطني لإدارة مخاطر الأمن السيبراني NFCRM-1:2025 كما وردت في المصدر، ونطاق الإلزام فيه مثل نطاق ECC.

الأنظمة والمورد

النظام	الوصف والمالك
نظام الموارد البشرية والرواتب	خدمة سحابية. بيانات الموظفين ورواتبهم وحساباتهم البنكية. المالكة: مديرة الموارد البشرية.
البريد والملفات السحابية	منصة بريد وتخزين سحابية لكل الموظفين. المالك: مدير تقنية المعلومات.
تطبيق تتبع الشحنات	على خادم سحابي. أسماء المستلمين وهواتفهم وعناوينهم. المالك: مدير تقنية المعلومات.
المورد: شركة سَنَد للحلول التقنية	مورد افتراضي للدعم الفني وإدارة الخوادم عن بعد، بعقد سنوي.

الأشخاص والأدوار

الدور	الاسم	المسؤولية في الحالة
الرئيس التنفيذي	أ. خالد	صاحب الصلاحية: يعتمد السياسات ويقبل المخاطر
لجنة الأمن السيبراني	يرأسها الرئيس التنفيذي	تشرف وتتابع كل ربع سنة
مسؤولة GRC	أ. ريم	الخط الثاني: المنهجية والمتابعة والتقارير

الدور	الاسم	المسؤولية في الحالة
محلل GRC متدرب	أنت	تساعد ريم في كل تطبيقات الكورس
مدير تقنية المعلومات	م. سلمان	يملك الأنظمة التقنية ويشرف على المورد
مديرة الموارد البشرية	أ. منى	مالكة نظام الموارد البشرية والرواتب
المدير المالي	أ. فهد	العقود والمشتريات

بطاقات مرجعية تحتاجها في التمارين

ملخصات من العرض لتحل دون الرجوع إليه. المصفوفة ملخص من الإطار الوطني لإدارة مخاطر الأمن السيبراني NFCRM-1:2025 (الشكلان 4 و5)، والمرجع المعتمد هو الوثيقة الرسمية في موقع الهيئة الوطنية للأمن السيبراني.

حروف RACI

الحرف	المعنى	القاعدة
R	المنفّذ (Responsible)	من يقوم بالعمل فعلاً. قد يكون أكثر من واحد.
A	المساءَل (Accountable)	من يحاسَب على النتيجة ويعتمدها. واحد فقط لكل نشاط.
C	المستشار (Consulted)	يؤخذ رأيه قبل التنفيذ: تواصل باتجاهين.
I	المُبلَّغ (Informed)	يُخبر بالنتيجة بعد التنفيذ: اتجاه واحد.

معايير بند السياسة الجيد

- يحدد النطاق: أي أنظمة أو أشخاص.
- يحدد المسؤول بالوظيفة.
- يحدد المدة أو التكرار.
- بصيغة إلزامية: «يجب» أو «تُ…».
- ينتج دليلاً يمكن طلبه.
- لا يكرر نص الضابط حرفياً.

مقياس الاحتمال

القيمة	المستوى	الإطار الزمني	أو: سهولة الاستغلال
5	شبه مؤكد	يتكرر غالباً، عدة مرات في السنة.	يستغله مهاجم غير محترف بأداة جاهزة.
4	محتمل	يحدث غالباً مرة في السنة.	يستغله مهاجم متقدم بأدوات خاصة.
3	غير مرجح	قد يحدث مرة كل 2 إلى 3 سنوات.	يستغله متقدم بشروط محددة فقط.
2	نادر	مرة كل 3 إلى 10 سنوات.	غير قابل للاستغلال مباشرة الآن.
1	نادر جداً	أقل من مرة كل 10 إلى 20 سنة.	لا يُعد قابلاً للاستغلال حالياً.

مقياس الأثر

القيمة	المستوى	الأثر عند المساس بالسرية أو السلامة أو التوافر
5	حرج	أثر كبير لا تحتمله الجهة، أو أثر على المستوى الوطني.
4	عالٍ	أثر كبير على الجهة.
3	متوسط	أثر ملموس على الجهة.
2	منخفض	أثر طفيف على الجهة.
1	منخفض جداً	لا أثر على الجهة، أو بيانات غير حساسة.

مستوى الخطر = الاحتمال × الأثر، وقاعدة القبول في رُفاد

المستوى	النطاق
منخفض جداً	1 إلى 2
منخفض	3 إلى 7

المستوى	النطاق
متوسط	8 إلى 14
عالٍ	15 إلى 19
حرج	20 إلى 25

المستوى	القرار في رُفاد
منخفض جداً أو منخفض	يقبله مالك الخطر ويوثقه
متوسط	خطة معالجة، أو قبول موثق من الرئيس التنفيذي
عالٍ أو حرج	معالجة إلزامية، وعرض على اللجنة

قاعدة القبول مثال تدريبي لرُفاد؛ كل جهة تحدد قيمها. وقبول الخطر قرار داخلي لا يلغي التزاماً نظامياً ولا يمنح إعفاءً تنظيمياً.

مقياس نتيجة التقييم

النتيجة	متى تُختار
مطبق	المتطلب موثق ومطبق، ويعمل باستمرار طوال فترة التقييم.
مطبق جزئياً	جزء من المتطلب مطبق، أو طُبق في جزء من الفترة فقط.
غير مطبق	لا دليل على التطبيق، أو الأدلة تنفي التطبيق.
لا ينطبق	المتطلب خارج النطاق، بمبرر موثق.

عناصر الملاحظة الخمسة

العنصر	ما يُكتب فيه
الوضع القائم	ما وجدته، بأرقام وتواريخ.
المعيار	المتطلب أو البند الذي يُقاس عليه.
السبب	لماذا حدث، بعد التحقق. إن لم تتحقق فاكتب «سبب محتمل».
الأثر	ماذا يعني للجهة، بلغة العمل.
التوصية	ما يعالج السبب، لا العَرَض فقط.

التمرين 1: صنّف مهام رُفاد: حوكمة أم مخاطر أم امتثال؟

الموضع في العرض	الشريحة 15، والإجابة في الشريحة 16
الوقت	4 دقائق
ما تحتاجه	تعريف الحوكمة والمخاطر والامتثال من الوحدة الأولى

لكل مهمة من مهام رُفاد: اكتب الحرف G أو R أو C، وسبباً من جملة واحدة.

#	المهمة في رُفاد	الحرف	السبب
1	الرئيس التنفيذي يعتمد سياسة الأمن السيبراني		
2	تقدير احتمال وأثر سرقة حاسوب عليه ملفات الرواتب		
3	جمع أدلة مراجعة الصلاحيات لتقييم الالتزام بـ ECC		
4	تشكيل لجنة الأمن السيبراني وتحديد مهامها		
5	اختيار خطة معالجة لخطر حساب المورد المشترك		
6	مطابقة عقد المورد مع بنود ECC 4-1-2		

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل سألت لكل مهمة: هل تضع قاعدة وتشرف، أم تقدر ما قد يحدث، أم تثبت الالتزام بمتطلب؟
- ☐ هل كتبت سبباً لكل حرف، لا الحرف وحده؟

التمرين 2: حوكمة أم إدارة أم تشغيل؟

الموضع في العرض	الشريحة 20، والإجابة في الشريحة 21
الوقت	3 دقائق
ما تحتاجه	شرح المستويات الثلاثة في الشريحة 19

أربعة أنشطة في مشروع واحد: فرض التحقق متعدد العوامل في رُفاد. اكتب المستوى وسبباً قصيراً لكل نشاط.

#	النشاط في رُفاد	المستوى	السبب
1	اعتماد قرار: «التحقق متعدد العوامل إلزامي للدخول عن بعد»		
2	خطة نشر التحقق متعدد العوامل خلال 6 أسابيع وميزانيتها		
3	تسجيل جهاز الموظف في تطبيق التحقق		
4	تقرير ربع سنوي للجنة عن نسبة الحسابات المفعّل عليها التحقق		

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل فرّقت بين من يقرر ويتابع (حوكمة)، ومن يخطط ويوفر الموارد (إدارة)، ومن ينفذ يومياً (تشغيل)؟
- ☐ في النشاط الرابع: من يستقبل التقرير، ولماذا؟

التمرين 3: التطبيق 1 من 4: تحديد المسؤوليات وصياغة بند سياسة

الموضع في العرض	المثال في الشرائح 29 إلى 31، والمطلوب في الشريحتين 32 و33، والإجابة في الشرائح 34 إلى 36
الوقت	15 دقيقة
ما تحتاجه	بطاقتا «حروف RACI» و«معايير بند السياسة الجيد»

المثال المحلول للرجوع إليه

المتطلب	ECC 2-2-3-5: يجب أن تغطي متطلبات إدارة هويات الدخول والصلاحيات بحد أدنى: المراجعة الدورية لهويات الدخول والصلاحيات.
الوضع في رُفاد	نظام الموارد البشرية والرواتب فيه 214 حساباً، ولا توجد مراجعة دورية للصلاحيات حتى الآن.
قرار رُفاد	قررت رُفاد مراجعة ربع سنوية لهذا النظام لأنه يحتوي رواتب الموظفين وحساباتهم البنكية. الضابط يقول «دورية» ولا يحدد المدة؛ الجهة تحددها بناءً على المخاطر وتوثقها.

النشاط	مالكة النظام	مدير الموظف	تقنية المعلومات	GRC
تصدير قائمة المستخدمين وصلاحياتهم	A		R	I
تأكيد حاجة كل موظف لصلاحيته	A	R		C
اعتماد نتيجة المراجعة	A/R	I	I	I
إزالة الصلاحيات غير المبررة	I		A/R	I
متابعة الإنجاز وحفظ الأدلة	A		C	R

بند السياسة: تُراجع هويات الدخول والصلاحيات في نظام الموارد البشرية والرواتب كل ثلاثة أشهر على الأقل. تعتمد مالكة النظام نتيجة المراجعة خلال 10 أيام عمل من تصدير القائمة، وتُزال الصلاحيات غير المبررة خلال 5 أيام عمل من الاعتماد، وتُحفظ أدلة المراجعة والإزالة سنتين على الأقل.

حالتك: إلغاء صلاحيات المغادرين

المتطلب	ECC 1-9-5: يجب مراجعة وإلغاء الصلاحيات للعامل مباشرة بعد انتهاء/إنهاء العلاقة الوظيفية مع الجهة.

ما وجدته في رُفاد:

- تسجل الموارد البشرية الاستقالات في نظام الموارد البشرية والرواتب.
- تعرف تقنية المعلومات بالمغادرين عبر رسائل غير رسمية من المدراء.
- المورد سَنَد يعطل حساب البريد حين تطلب منه تقنية المعلومات ذلك.
- لا أحد يتحقق من حسابات نظام الرواتب وتطبيق التتبع والوصول عن بعد.
- الشهر الماضي غادر 4 موظفين، وبقي حسابان منهم نشطين بعد 3 أسابيع.

المطلوب:

1. اكتب خمسة أنشطة لعملية إلغاء صلاحيات المغادرين.
2. املأ مصفوفة RACI، مع مسؤول A واحد لكل نشاط.
3. اكتب بند سياسة من جملتين أو ثلاث يحقق معايير البند الجيد.

النموذج

النشاط	الموارد البشرية	مدير الموظف	تقنية المعلومات	GRC
النشاط 1				

النشاط	الموارد البشرية	مدير الموظف	تقنية المعلومات	GRC
النشاط 2				
النشاط 3				
النشاط 4				
النشاط 5				

بند السياسة	

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ لكل نشاط A واحد فقط، وكل نشاط له A.
- ☐ هل غطيت كل الأنظمة: البريد، ونظام الرواتب، وتطبيق التتبع، والوصول عن بعد؟
- ☐ هل البند يحدد النطاق، والموعد، والمسؤول، والدليل؟ وهل يمكن لمدقق أن يطلب دليلاً عليه؟
- ☐ هل جعلت GRC منفذاً للإلغاء؟ إن فعلت فراجع دور GRC.

التمرين 4: التطبيق 2 من 4: كتابة خطر وتقييمه وتحديد معالجته

الموضع في العرض	المثال في الشريحة 40 وما بعدها حتى الشريحة 50، والمطلوب في الشريحتين 51 و52، والإجابة في الشرائح 53 إلى 56
الوقت	20 دقيقة
ما تحتاجه	بطاقات الاحتمال والأثر والمستوى وقاعدة القبول

المثال المحلول للرجوع إليه: صف في سجل المخاطر

وصف الخطر	بسبب حفظ ملفات تصدير الرواتب على حاسوب محمول غير مشفر، قد يؤدي فقدانه أو سرقته إلى اطلاع غير مصرح به على رواتب 200 موظف وحساباتهم البنكية، مما يضر الموظفين ويعرض رُفاد لمخالفة نظام حماية البيانات الشخصية ولضرر في سمعتها.
الأصل	حاسوب أخصائي الرواتب وملفات تصدير الرواتب
الضوابط الحالية	كلمة مرور لحساب الجهاز، وسياسة الاستخدام المقبول لا تشفير للقرص.
الاحتمال	3: يتنقل الموظف يومياً بالحاسوب، وسُجلت في رُفاد سرقة حاسوب واحدة خلال 3 سنوات: «غير مرجح» قد يقع مرة كل 2 إلى 3 سنوات.
الأثر	4: تسرب بيانات حساسة لكل الموظفين بأثر كبير على الجهة: «عالٍ».
التقييم الحالي	3 × 4 = 12 · متوسط
مالك الخطر	مديرة الموارد البشرية
المعالجة	التخفيف: تشفير القرص الكامل لحواسيب الموارد البشرية والمالية، وحفظ ملفات الرواتب في مجلد سحابي مقيد بدل الجهاز.
مالك الإجراء والموعد	مدير تقنية المعلومات · 30 يوماً
المتبقي المتوقع	3 × 2 = 6 · منخفض
افتراضات المتبقي	• التشفير مفعّل ومُتحقق منه على كل الأجهزة المعنية، لا على بعضها. • الجهاز محمي بكلمة مرور قوية، ومفاتيح الاسترداد محفوظة بأمان. • لا تبقى نسخ من ملفات الرواتب خارج المجلد المقيد.
المتابعة	تتحقق GRC من تقرير التشفير بعد 30 يوماً، وتحدّث السجل.

حالتك: حساب المورد المشترك

ما وجدته في رُفاد:

- سَنَد يدير خادم تطبيق التتبع عن بعد بأداة دعم مكشوفة على الإنترنت.
- حساب إداري مشترك واحد «sanad-admin» يستخدمه 5 فنيين.
- كلمة المرور لم تتغير منذ 2023، ولا يوجد تحقق متعدد العوامل.
- الوصول مفتوح على مدار الساعة دون طلب أو موافقة.
- الأداة تحفظ سجلات الجلسات 30 يوماً، ولا أحد يراجعها.
- العقد فيه بند سرية فقط لا إبلاغ عن الحوادث ولا التزام بسياسات رُفاد.
- الخادم يحفظ أسماء المستلمين وهواتفهم وعناوينهم: نحو 50 ألف مستلم شهرياً.

المطلوب:

1. اكتب الخطر بصيغة: بسبب… قد… مما يؤدي إلى…
2. اذكر الضوابط الحالية.
3. قدّر الاحتمال والأثر بأوصاف المصفوفة، وبرر كلاً منهما، ثم احسب المستوى.
4. اقترح معالجة: خيار، وثلاثة إجراءات، لكل منها مالك وموعد.
5. قدّر الخطر المتبقي المتوقع واذكر افتراضاتك.

النموذج: صف سجل المخاطر

وصف الخطر	بسبب... قد... مما يؤدي إلى...
الأصل والبيانات	
الضوابط الحالية	
الاحتمال ومبرره	القيمة: ... المبرر:
الأثر ومبرره	القيمة: ... المبرر:
المستوى	... × ... = ... المستوى:
مالك الخطر	
خيار المعالجة	

الإجراء	**المالك**	**الموعد**

المتبقي المتوقع	... × ... = ... المستوى:
افتراضاتك	
القرار حسب قاعدة القبول	

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل الوصف يربط سبباً بحدث بأثر، أم كتبت ثغرة فقط؟
- ☐ هل لكل درجة مبرر من أوصاف المقياس، ولماذا لم تختر الدرجة التي فوقها؟
- ☐ هل لكل إجراء مالك واحد وموعد؟ وهل المالك من الخط الأول لا GRC؟
- ☐ في المتبقي: ما الذي يغيره كل إجراء، الاحتمال أم الأثر؟ وهل كتبت افتراضاتك؟

التمرين 5: التطبيق 3 من 4: فحص أدلة ضابط وتحديد نتيجة التقييم

الموضع في العرض	المثال في الشرائح 68 إلى 70، والمطلوب في الشرائح 71 إلى 73، والإجابة في الشرائح 74 إلى 76
الوقت	20 دقيقة
ما تحتاجه	بطاقة «مقياس نتيجة التقييم»، وهي في الشريحة 67

المثال المحلول للرجوع إليه

المتطلب	ECC 2-2-3-2: التحقق متعدد العوامل للدخول عن بعد وللحسابات ذات الصلاحيات الهامة.
النطاق والفترة	دخول الموظفين عن بعد عبر الشبكة الافتراضية VPN. الفترة: 1 يناير إلى 30 يونيو 2026. الحسابات ذات الصلاحيات الهامة تُقيّم منفصلة.
مالك الضابط	مدير تقنية المعلومات

الدليل	ما وصل
د1	معيار الوصول عن بعد، معتمد فبراير 2026: التحقق متعدد العوامل إلزامي لكل مستخدمي VPN.
د2	لقطة إعداد من بوابة VPN بتاريخ 5 يوليو 2026: التحقق إلزامي لمجموعة «VPN-Users».
د3	سجل تغييرات الإعداد: فُعّل الإلزام في 10 مارس 2026.
د4	أعضاء مجموعة «VPN-Users»: 38 حساباً. سجل الاتصالات: 41 حساباً اتصلت خلال الفترة.
د5	عينة 25 اتصالاً بعد 10 مارس: 23 بعامل ثانٍ، و2 بكلمة المرور فقط، كلاهما من حساب «test».

سؤال الفحص	ما وجدناه
هل المتطلب موثق؟	نعم: د1 يغطي المتطلب.
هل الإعداد مطبق، ومنذ متى؟	نعم منذ 10 مارس (د3). اللقطة د2 بعد الفترة، فلا تكفي وحدها.
هل يعمل طوال الفترة ولكل المستخدمين؟	لا لا إلزام قبل 10 مارس، و3 حسابات خارج المجموعة (د4، د5).

النتيجة: مطبق جزئياً. المتطلب موثق ومطبق على المجموعة الرئيسية منذ 10 مارس، لكنه لم يعمل في أول الفترة، وتوجد 3 حسابات تتصل دون عامل ثانٍ.
لا نعمم العينة: الاتصالان الضعيفان من حساب واحد. مقارنة المجتمع كاملاً (41 مقابل 38) حددت الحسابات الثلاثة بدقة.

حالتك: مراجعة صلاحيات نظام الرواتب

المتطلب	ECC 2-2-3-5: المراجعة الدورية لهويات الدخول والصلاحيات.
النطاق والفترة	نظام الموارد البشرية والرواتب. الفترة: 1 يناير إلى 30 يونيو 2026 (ربعان).
المعيار المعتمد	معيار التحكم بالوصول، معتمد 15 يناير 2026: مراجعة كل 3 أشهر، واعتماد خلال 10 أيام عمل، وإزالة خلال 5 أيام عمل.

هذا الضابط هو الذي كتبت رُفاد بنده في مثال التطبيق 1. الآن نفحص: هل التزمت به فعلاً؟

الدليل	ما وصل
د1	معيار التحكم بالوصول المعتمد في 15 يناير 2026.
د2	ملف مراجعة الربع الأول: تصدير 29 مارس، 214 حساباً، اعتمدته مالكة النظام في 8 أبريل، و12 حساباً للإزالة.
د3	تذاكر الإزالة: 9 حسابات أزيلت حتى 12 أبريل، و3 أزيلت في 20 مايو.
د4	لا ملف لمراجعة الربع الثاني. بريد من تقنية المعلومات: «تأجلت بسبب ترحيل النظام إلى إصدار جديد في يونيو».
د5	تصدير الحسابات النشطة في 2 يوليو: 221 حساباً، منها حسابان لموظفين غادروا في مايو.
د6	مقابلة مع مالكة النظام: «نراجع الصلاحيات عندما يطلب المدير».

المطلوب:

1. لكل دليل: ماذا يثبت؟ التوثيق، أم التطبيق، أم الاستمرار خلال الفترة؟
2. حدد نتيجة التقييم من المقياس، وبرر اختيارك في ثلاث جمل.
3. ما الأدلة الإضافية التي ستطلبها قبل إغلاق التقييم؟

النموذج

الدليل	ماذا يثبت؟ (توثيق، تطبيق، استمرار، أو لا شيء وحده)	ملاحظتك
د1		
د2		
د3		
د4		
د5		
د6		

النتيجة	☐ مطبق ☐ مطبق جزئياً ☐ غير مطبق ☐ لا ينطبق
المبرر في ثلاث جمل	
أدلة إضافية ستطلبها	

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل قرأت تاريخ كل دليل: داخل فترة التقييم أم خارجها؟
- ☐ هل حسبت المهل بأيام العمل من المعيار، لا بالانطباع؟
- ☐ هل فرّقت بين ما يثبته الدليل وما يدّعيه؟ البريد والمقابلة ادعاءان حتى تتحقق منهما.
- ☐ هل تعميمك بحجم ما رأيت؟ 3 حالات من 12 ليست «كل الحالات».

التمرين 6: التطبيق 4 من 4: كتابة ملاحظة وخطة تصحيح

الموضع في العرض	الشرح في الشريحتين 77 و78، والمثال في الشريحتين 79 و80، والمطلوب في الشريحتين 81 و82، والإجابة في الشرائح 83 إلى 85
الوقت	20 دقيقة
ما تحتاجه	نتيجتك في التطبيق 3، وبطاقة «عناصر الملاحظة الخمسة»

المثال المحلول للرجوع إليه

العنوان	حسابات تتصل بالشبكة عن بعد دون تحقق متعدد العوامل
الوضع القائم	لم يكن التحقق متعدد العوامل مفروضاً على اتصالات VPN حتى 10 مارس 2026. وبعد التفعيل، اتصلت 3 حسابات من 41 من خارج مجموعة التحقق، منها حساب لمستشار انتهى عقده.
المعيار	ECC 2-2-3-2، ومعيار الوصول عن بعد في رُفاد (فبراير 2026).
السبب	أُضيفت الحسابات الثلاثة يدوياً استثناءً «مؤقتاً» عند التفعيل، دون إجراء موافقة أو مراجعة. تحققنا من ذلك بسجل التغييرات ومقابلة فريق تقنية المعلومات.
الأثر	من يعرف كلمة مرور أحد الحسابات الثلاثة يستطيع دخول الشبكة الداخلية دون عامل ثانٍ، ومنها حساب لشخص لم يعد يعمل مع رُفاد.
التوصية	إزالة الاستثناءات الثلاثة، واعتماد إجراء للاستثناءات بموافقة ومدة ومراجعة، ومطابقة دورية بين مستخدمي VPN ومجموعة التحقق. التفاصيل في خطة التصحيح.

الإجراء	المالك	الموعد	دليل الإغلاق
تعطيل حساب المستشار السابق	مدير تقنية المعلومات	يوم عمل واحد	تصدير يبين الحساب معطلاً، وسجل التغيير
نقل الحسابين إلى مجموعة التحقق أو تعطيلهما	مدير تقنية المعلومات	5 أيام عمل	تصدير المجموعة، وسجل VPN لأسبوع
اعتماد إجراء استثناءات بموافقة ومدة ومراجعة	مسؤولة GRC	30 يوماً	الإجراء المعتمد، وسجل الاستثناءات
مطابقة شهرية: مستخدمو VPN مقابل المجموعة	مدير تقنية المعلومات	بدءاً من الشهر القادم	تقارير 3 أشهر متتالية

حالتك: ملاحظة نظام الرواتب

المطلوب:

1. اكتب ملاحظة بعناصرها الخمسة لنتيجة التطبيق 3 (مراجعة صلاحيات نظام الرواتب).
2. السبب: افترض أنك تحققت من سجل الترحيل ووجدت أنه لم يُعتمد أي استثناء لتأجيل المراجعة.
3. اكتب خطة تصحيح من 4 إجراءات: المالك، والموعد، ودليل الإغلاق.

النموذج: الملاحظة

العنوان	
الوضع القائم	أرقام وتواريخ…
المعيار	

السبب	ما تحققت منه…
الأثر	
التوصية	ما يعالج السبب

النموذج: خطة التصحيح

الإجراء	المالك	الموعد	دليل الإغلاق

إعادة الاختبار: متى وكيف؟	

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل الوضع القائم أرقام وتواريخ من الأدلة، بلا أحكام عامة؟
- ☐ هل السبب يصف العملية، ولم تلم شخصاً بالاسم؟
- ☐ هل فيها إجراء فوري يزيل الخطر الآن، وإجراء يمنع التكرار؟
- ☐ لكل إجراء: مالك واحد بالوظيفة، وموعد، ودليل إغلاق.

التمرين 7: ما الذي ينطبق على كل جهة؟

الموضع في العرض	الشريحة 98، والإجابة في الشريحتين 99 و100
الوقت	10 دقائق
ما تحتاجه	أسئلة الانطباق في الشريحة 97

الجهة	الوصف
رُفاد	شركة خاصة للتوصيل، تعالج بيانات موظفين ومستلمين، لا تعالج بيانات بطاقات بنفسها.
شركة «مدى التقنية»	شركة افتراضية تابعة لوزارة، تقدم خدمات تقنية للوزارة.
شركة «دفع سريع»	شركة تقنية مالية افتراضية مرخصة من البنك المركزي السعودي، تعالج مدفوعات بالبطاقات.

لكل خانة: نعم، أو لا، أو يعتمد، مع سبب قصير.

الجهة	ECC-2:2024	نظام حماية البيانات الشخصية	إطار ساما للأمن السيبراني	PCI DSS
رُفاد				
شركة «مدى التقنية»				
شركة «دفع سريع»				

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل حددت لكل جهة: نوعها، وقطاعها والجهة المنظمة، ونوع بياناتها، وعقودها؟
- ☐ هل فرّقت بين «ملزم» و«متبنى طوعاً»؟

التمرين 8: اختر الشهادة المناسبة

الموضع في العرض	الشريحة 118، والإجابة في الشريحة 119
الوقت	8 دقائق
ما تحتاجه	مقارنة الخبرة في الشريحة 114، وطريقة الاختيار في الشريحة 115

الشخص	الوضع	شهادة الآن	شهادة لاحقاً	السبب
سارة	خريجة نظم معلومات، بلا خبرة، تريد وظيفة محللة امتثال خلال سنة.			
عبدالله	محاسب بخبرة 4 سنوات في المراجعة الداخلية، يريد التحول إلى تدقيق تقنية المعلومات.			

الشخص	الوضع	شهادة الآن	شهادة لاحقاً	السبب
نورة	محامية بخبرة سنتين، مهتمة بحماية البيانات الشخصية.			

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل شهادة «الآن» لا تشترط خبرة لا يملكها الشخص؟
- ☐ هل تخدم الشهادة الوظيفة المستهدفة، لا الشهرة فقط؟

التمرين 9: صفحة مشروع تقييم الصلاحيات

الموضع في العرض	الشريحة 125، والإجابة في الشريحة 126
الوقت	10 دقائق
ما تحتاجه	إجاباتك في التطبيقين 3 و4

اكتب صفحة تعريفية لمشروعك من التطبيقين 3 و4، كما ستنشرها في ملف أعمالك.

عنوان المشروع	
المشكلة	
ما فعلته	
النتيجة	
ما تعلمته	
الملفات المرفقة	

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل ذكرت أن البيانات افتراضية؟
- ☐ هل «ما فعلته» أفعال وأرقام، لا وصف عام؟

التمرين 10: أعد صياغة ثلاثة أسطر في السيرة

الموضع في العرض	الشريحة 134، والإجابة في الشريحة 135
الوقت	8 دقائق
ما تحتاجه	معادلة السطر في الشريحة 131

أعد صياغة كل سطر بالمعادلة: فعل قوي + ماذا فعلت + بأي طريقة + النتيجة أو الرقم. بالإنجليزية، ومن تطبيقاتك 2 و3 و1.

السطر الضعيف	صياغتك
Responsible for risk assessment.	
Helped with access review.	

السطر الضعيف	صياغتك
Familiar with NCA ECC.	

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل يبدأ كل سطر بفعل، وفيه رقم أو نتيجة؟
- ☐ هل وصفت العمل بحجمه الحقيقي، بلا مبالغة؟

التمرين 11: عنوانك المهني وافتتاح نبذتك في لينكدإن

الموضع في العرض	الشريحة 142، والإجابة في الشريحة 143
الوقت	8 دقائق
ما تحتاجه	الشريحتين 138 و139

العنوان المهني **الوظيفة | مجالان أو ثلاثة | دليل**	
افتتاح النبذة **جملتان: من أنت، وأقوى دليل من مشاريعك**	

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل في العنوان كلمات يبحث بها مسؤول التوظيف؟
- ☐ هل الدليل مشروع أو شهادة حقيقية لديك؟

التمرين 12: قصتك بطريقة STAR

الموضع في العرض	الشريحة 148، والإجابة في الشريحة 149
الوقت	8 دقائق
ما تحتاجه	المثال المحلول في الشريحة 147، وإجاباتك في التطبيقين 3 و4

السؤال: «حدثنا عن مرة اكتشفت فيها مشكلة في ضابط ولم يكن الدليل واضحاً.»

S الموقف	
T المهمة	
A ما فعلته أنا	
R النتيجة	

قبل أن تقارن بالإجابة، راجع نفسك:

- ☐ هل الإجراء A هو الجزء الأطول، وبصيغة «أنا»؟
- ☐ هل النتيجة R فيها رقم أو قرار أو ما تعلمته؟
- ☐ هل يمكنك قولها في دقيقة إلى دقيقتين؟